Caso de estudio — Asegurar la plataforma web de una firma legal

> **Belona Cybersecurity** · 2026 Rol: responsable técnico único · Cliente: firma legal (Cliente A) Plataforma: Firebase / Google Cloud *English version:* `english/case-study-devsecops-troubleshooting-EN.md`
>
> **Léalo primero.** Es el resumen ejecutivo de todo el trabajo; los demás documentos desarrollan cada pieza.

El problema

La firma tenía un sitio web que **funcionaba**, y esa es exactamente la situación más común y más engañosa: nada estaba roto, así que nada parecía urgente.

Lo que no tenía:

Autenticación del panel	solo usuario y contraseña
Control de acceso	cualquiera con cuenta veía todo
Formulario de contacto	alojado en un tercero
Respaldos	ninguno
Monitoreo	ninguno
Cumplimiento de protección de datos	sin consentimiento ni política

Y guardaba **expedientes de clientes**: documentos legales con datos personales.

Nada de esto produce síntomas hasta que es tarde. Un sitio sin respaldos se ve idéntico a uno con respaldos, hasta el día que hay que restaurar.

El objetivo

Llegar a una postura de **defensa en profundidad** —prevención, detección y recuperación— cubriendo el modelo **AAA**: autenticación, autorización y registro de actividad.

Con dos restricciones del negocio, que condicionaron todas las decisiones:

- **sin costo recurrente añadido**
- **sin añadir terceros** a la frontera de confianza

La segunda es la que más orientó el trabajo. Cada servicio externo que toca datos de clientes es un sistema más que hay que vigilar, un contrato más que revisar, y una superficie más que puede fallar sin aviso.

Qué se implementó

Autenticación — y un bloqueo que costó entender

Verificación en dos pasos con código temporal en el panel de administración.

El problema real fue de depuración: el registro del segundo factor fallaba siempre. La causa estaba en el momento: se intentaba registrar el factor cuando la sesión aún no estaba completamente resuelta, así que el usuario autenticado todavía no existía para el sistema.

> El registro de un segundo factor tiene que ocurrir contra una sesión **completamente resuelta**, no contra una que está terminando de cargar.

Es el tipo de fallo que no aparece en ninguna guía: la configuración era correcta, el orden de ejecución no.

Autorización por roles

Tres roles con permisos distintos: **administrador** (todo), **abogado** (contenido, consultas y expedientes) y **editor** (solo blog).

Aplicado en **dos capas**:

1. **Reglas de seguridad del servidor** — la que de verdad decide
2. **La interfaz** — oculta lo que el rol no puede usar

La segunda sola **no es seguridad**: ocultar un botón no impide llamar a la función que hay detrás. Está para que la experiencia tenga sentido, no para proteger. Confundir las dos es uno de los errores más frecuentes.

Formulario de contacto propio

Se reemplazó el servicio externo por una función de servidor que valida en el servidor, exige verificación anti-abuso, guarda la consulta y envía el aviso por correo.

Lo importante no es que funcione igual: es que los datos de quien escribe ya no pasan por un tercero. En una firma legal, el primer mensaje de alguien puede contener información delicada antes de que exista ninguna relación profesional.

Expedientes y documentos privados

Gestión de expedientes con carga de documentos a **almacenamiento privado**: sin enlaces públicos con token, con descarga autenticada, campos de auditoría y límites de tamaño y tipo aplicados por reglas del servidor.

Un enlace público con token parece seguro porque es largo e impredecible — pero **se puede reenviar, queda en el historial del navegador y no caduca**. Quien lo tenga, entra.

Registro de actividad

Colección de auditoría **de solo escritura**: se puede crear, nadie puede editar ni borrar, y solo el administrador puede leer. Registra las acciones sensibles del lado del servidor, incluido el acceso del propio administrador.

Un registro que el administrador puede borrar no es un registro. Si la persona con más poder puede eliminar la evidencia de lo que hizo, el control no existe.

Prueba de intrusión autorizada, con remediación

Prueba en tres fases: reconocimiento, pruebas de autorización e intentos de escalada de privilegios.

🔴 **Hallazgo crítico:** el hosting servía el directorio de control de versiones del proyecto. Cualquiera podía descargar el código fuente completo, el historial **y un token de acceso al repositorio** que había quedado en la configuración.

Causa: la configuración publicaba toda la carpeta del proyecto, y el filtro de exclusión no cubría ese directorio. Nadie lo había puesto ahí a propósito: estaba por omisión.

Corregido: se excluyeron esos directorios del hosting, se añadieron cabeceras de seguridad, y se verificó que ya no respondieran.

✅ **Lo que resistió:** el control de acceso por roles, la verificación anti-abuso y las reglas de almacenamiento se probaron en vivo —como anónimo y como usuario con rol limitado— y **ninguno cedió**. Un editor autenticado no pudo asignarse permisos de administrador ni leer datos fuera de su rol.

> Un informe que solo lista lo que falló está incompleto. **Saber qué resistió es tan importante como saber qué cedió**, porque es lo que indica dónde no hace falta gastar.

Recuperación

Cuatro capas: recuperación a un punto en el tiempo (7 días), copias diarias (14 días), versionado de documentos (90 días) y una copia semanal fuera del sitio, en otra cuenta de almacenamiento.

Ver `recuperacion-ante-desastres.md` — ahí está el detalle, incluido un hallazgo posterior: una de esas capas figuraba como implementada y nunca se había activado.

Detección

- **Vigilancia de integridad de archivos:** huella criptográfica de los archivos del sitio en producción, comparada cada seis horas de forma automática, con alerta si algo cambia sin haberlo desplegado.
- **Alertas sobre los registros** del sistema ante errores.
- **Cadena de suministro:** revisión automática de dependencias en cada cambio. Se pasó de **20 vulnerabilidades (1 crítica, 5 altas) a 8 moderadas**.

La vigilancia de integridad responde una pregunta concreta: *¿alguien modificó el sitio sin que yo lo desplegara?* Sin ella, un atacante que inserte código en una página puede quedarse meses sin que nadie lo note.

Gestión de secretos

Las claves de servicios externos se movieron de un archivo en el proyecto a un **almacén cifrado gestionado**.

Un archivo de configuración con credenciales **sigue siendo un archivo en el disco**: lo copia un respaldo, lo sube un `git add` descuidado, lo lee cualquiera con acceso al equipo. El almacén cifrado quita el archivo de la ecuación.

Cumplimiento normativo

Captura de consentimiento con prueba almacenada, cláusula de transferencia internacional en la política de privacidad, y una hoja de ruta documentada de lo que falta a nivel organizativo.

Lo pendiente se dejó escrito, no omitido. Un informe de cumplimiento que solo enumera lo hecho es publicidad.

Documentación producida

- **Modelo de amenazas PASTA** (etapas 3–7): descomposición, análisis de amenazas, mapeo a vulnerabilidades conocidas, árboles de ataque con los controles validados, y matriz de riesgo residual.
- **Playbooks de respuesta a incidentes** basados en NIST.
- **Programa de formación** del personal, alineado a CIS Control 14.

Resultados

AAA completo	autenticación, autorización y registro de actividad
Defensa en profundidad	prevención, detección y recuperación
Un hallazgo crítico	exposición de código y credencial, encontrado y corregido **antes** de ser explotado
Cadena de suministro	de 20 vulnerabilidades a 8 moderadas
Sin terceros añadidos	y sin costo recurrente nuevo

Lo que este caso enseña

1. Que funcione no significa que esté bien. La plataforma operaba con normalidad mientras servía su propio código fuente y una credencial a cualquiera que supiera pedirlos.

2. Los controles se verifican, no se declaran. El hallazgo crítico apareció al probar, no al revisar la configuración. Y meses después, otro control documentado como activo resultó no estarlo.

3. Saber qué resistió vale tanto como saber qué cedió. Las pruebas de escalada de privilegios no encontraron nada — y ese resultado negativo, obtenido intentándolo de verdad, es información útil.

Caso del portafolio técnico de Belona Cybersecurity. Trabajo real sobre una plataforma en producción, con autorización del propietario.
